



Mekanisme Deployment :

- Setiap Service adalah satu Git repo tersendiri (tidak satu repo untuk keseluruhan)
- Setiap repo di deploy dalam satu container tersendiri
- Service container yang harus dibuat dalah (frontend, RBAC, Master, Transaksi, Document, dan API Gateway)
- Container bisa menggunakan Docker Compose atau Kubernetes
- Setiap Container yang memerlukan Penyimpanan Data harus dibuat pointing Persistent Storage

Keamanan System & API Gateway

- **Access & Refresh Token:** Login menggunakan JWT Token (*short-lived* ~15 menit) dan Refresh Token di *HttpOnly Cookie*. Gateway memverifikasi token sebelum meneruskan request ke service.
- **Isolasi Service (Private VPC):** Semua *microservice* disembunyikan di dalam jaringan privat (*private subnet*). Hanya API Gateway yang bisa diakses publik, service internal tidak bisa ditembak langsung dari luar.
- **CORS & Rate Limit:** API Gateway membatasi akses domain hanya untuk Frontend React TS dan membatasi jumlah request (misal max 100/menit) untuk mencegah serangan DDoS.

Proteksi Celah Keamanan (XSS, SQLi, CSRF)

- **Anti SQL Injection:** Wajib menggunakan *Prepared Statements* / ORM (Prisma/Knex di Node.js, Eloquent di Laravel) untuk semua *query* database.
- **Anti XSS:** Sanitisasi input string di backend (misal: **DOMPurify**) dan gunakan mekanisme *auto-escaping* bawaan React di frontend.

- **Anti CSRF:** Penggunaan token JWT pada header request bersama cookie `SameSite=Strict` mengamankan transaksi dari manipulasi *cross-site*.
- **anti IDOR :** setiap Path hanya dapat diakses oleh user yang berhak.

Keamanan Upload & Verifikasi Dokumen

- **Validasi File Ketat**
Jangan hanya mengandalkan ekstensi file (`.pdf`, `.jpg`) untuk menentukan jenis file — ekstensi bisa dipalsukan. Cek **magic bytes** (signature biner di awal file) untuk memastikan file yang diunggah benar-benar PDF atau JPG sesuai klaimnya. Setelah itu, jalankan file melalui **antivirus scanner (ClamAV)** sebelum disimpan, untuk memastikan tidak ada malware.
- **Private Storage**
File tidak boleh disimpan di folder publik yang bisa diakses langsung lewat URL biasa. Simpan di direktori yang di-*mount* ke **persistent volume** container Docker, sehingga data tetap aman dan tidak hilang saat container di-restart atau redeploy.
- **Akses File via Endpoint / Presigned URL**
File tidak boleh punya URL statis yang bisa ditebak/diakses siapa saja. Akses harus melalui endpoint API yang mengecek autentikasi & otorisasi user (apakah user ini berhak lihat file ini), atau menggunakan **presigned URL** yang punya masa berlaku (expiry) dan hanya valid untuk user/permission tertentu.
- **Struktur Folder Rapi**
Kelompokkan file berdasarkan **Kode Permohonan** (misal: `/storage/permohonan/{kode_permohonan}/UUIDnamaFile`), dan saat menyimpan, rename nama file aslinya menjadi **UUID acak** (bukan nama asli dari user) untuk menghindari collision nama file dan mencegah info leakage dari nama file asli.
 - **Contoh:** `/storage/PRM-2026-001/ktp_9b1deb4d-3b7d.pdf`

Mekanisme Form Input Tahapan

- Penginputan data dilakukan secara bertahap, tidak dilakukan sekaligus dalam satu form.
- Form input dibagi ke dalam beberapa section/widget sesuai dengan kelompok atau jenis data yang akan diinput.
- Data pada setiap section disimpan ke database ketika pengguna menekan tombol “Selanjutnya” atau “Selesai”.
- Dengan mekanisme tersebut, data yang telah diinput pada setiap section tetap tersimpan dan dapat dilanjutkan ke section berikutnya.